Secure By Design

EDUCATE. EMPOWER. SECURE THE FUTURE.

COURSE 1.13 / COMPANION WORKBOOK

Bring in the fleet

50 Windows endpoints, managed from first boot

Join the fifty-workstation fleet to a network that is ready for it: DHCP addressing, OU landing with STIG policy at first boot, Windows LAPS for every local administrator, certificate autoenrollment at scale, 802.1X port admission through NPS on SBD-DHCP01, and a sampled proof with the whole rollout observed by the logging pipeline.

MATERIALS EDITION 1.5 / COURSE 1.13

Updated 14 October 2026 · sbd-workstation-fleet

NAME _____ / DATE _____

© 2026 Secure By Design Team LLC.

Table of contents

Read each lesson alongside the interactive guide and the video. Use the record tables to write down what you actually observe — the workbook is your evidence, not the guide.

Before you start

01 Prepare the fleet rollout

02 Join the pilot and inspect first boot

03 Manage local administrators with Windows LAPS

04 Autoenroll the fleet's certificates

05 Admit only enrolled devices with 802.1X

06 Scale to fifty, enforce 802.1X, and prove by sample

07 Delta scan the fleet and hand off

Course review and sign-off

> **HOW TO USE IT** Each lesson page has the same shape: what you will learn, the build steps, the commands that verify them, and a record table. Fill the table from your own environment — never from the sample values.

Before you start

Fifty endpoints join a network that is finally ready for them: addressed by DHCP, landed by OU redirect, hardened by policy at first boot, certified by autoenrollment, and watched by the pipeline from their first sign-in. Tier 0 steps run from AdminJumpBox01, Tier 1 steps on SBD-DHCP01 from SBD-ADMIN-SRV01, and Tier 2 steps inside SBD-ADMIN-PC01; each seat keeps its part of the record under C:\Evidence\workstation-fleet. The sample names run SBD-PC01 through SBD-PC50; match them to your own plan.

Prerequisites

- ☐ Complete courses 1.6–1.12: the course 1.6 PKI with its SBD Computer Authentication template and the SBD Certificate Autoenrollment GPO at the domain root, SBD-DHCP01 (course 1.7), whose relay course 1.7 verified, the three administration seats (course 1.8), with SBD-ADMIN-PC01's own SCC copy and first baseline, and the logging pipeline (courses 1.10–1.12), on the network's routed, segmented VLANs.
- ☐ Prepare a patched Windows client reference image (or template) for the fifty endpoints, obtained through the approved offline media process.
- ☐ Confirm the Workstations OU and the computer redirect from course 1.5, and the Defense Information Systems Agency (DISA) Security Technical Implementation Guide (STIG) Group Policy objects (GPOs) for your Windows client release, imported in course 1.5 from the package course 1.4 staged and still unlinked there. Lesson 7 reuses SBD-ADMIN-PC01's own SCC copy, which course 1.8 installed with the Windows client benchmark course 1.4 staged, and the checked installer and connected-side-hashes.csv course 1.8 kept in C:\Staging\DISA there.
- ☐ Confirm the VLAN 80 access switch supports 802.1X port authentication, including a monitor (audit) mode that logs each result without blocking traffic. No new server is needed: the Network Policy Server (NPS) role goes on SBD-DHCP01.

What this course builds

- Roll fifty endpoints in waves that land hardened, addressed, and registered untouched.
- Manage every local administrator with Windows LAPS under the tier model.
- Admit only enrolled machines to VLAN 80 ports with 802.1X, proven in monitor mode before enforcement.
- Prove the fleet with a defined sample, a failure rule, and pipeline-observed joins.

Systems in scope

RECORD	YOUR OBSERVATION
50 Windows PCs — name, address, OS build	
SBD-DHCP01 — name, address, OS build	

© 2026 Secure By Design Team LLC.

RECORD	YOUR OBSERVATION
SBD-SUBCA01 — name, address, OS build	

LESSON 01 / ABOUT 30 MIN

Prepare the fleet rollout

> **WHY THIS MATTERS** Fifty of anything needs a factory, not fifty craft projects. Settle the image, the names, the join account, and the policy links so every endpoint is born identical — then prove it on paper before proving it on metal.

In this lesson you will

- Finalize the reference image and naming plan for fifty endpoints.
- Create a least-privilege join account scoped to the Workstations OU.
- Link the Windows client STIG policies and the local Administrators, firewall and DNS registration policies to the Workstations OU before any join, below course 1.8's tier logon GPO.

Follow the build

1. Finalize the Windows client reference image: current patches via the approved media process, no preinstalled extras, one local administrator account for Windows LAPS to manage (the Windows client STIG disables the built-in Administrator), and a generalized state so each clone takes its own identity. Record the image version and hash — it is the fleet's common ancestor and belongs in evidence.
2. Write the naming and rollout plan: SBD-PC01–SBD-PC50, addressed by the course 1.7 DHCP scope, joined in waves (pilot of three, then batches) rather than all fifty at once.
3. From AdminJumpBox01, create a dedicated domain-join account delegated only Create Computer objects on the Workstations OU — no broader privilege rides along with fifty join operations — and record it beside the same delegation course 1.8 gave SBD Tier 2 Admins for its test client. The course 1.5 redirect already guarantees machines land in that OU. Add a GPO, linked only to the Workstations OU, that makes SBD Tier 2 Admins the managing group in each PC's local Administrators (Group Policy Preferences, Local Users and Groups), as course 1.8 did by hand on its test client; course 1.8's tier logon GPO already denies sign-ins there to SBD Tier 0 Admins, SBD Tier 1 Admins and SBD Audit Custodians.
4. Link the DISA Windows client policies that course 1.5 imported and left unlinked to the Workstations OU now — the computer policy, the user policy, and course 1.5's loopback (Merge) GPO, as course 1.8 did for Admin Workstations — so the very first pilot boots into the hardened state, and note that the Windows client's own secure defaults will already satisfy some checks, just as Windows Server's did. Link each of them below course 1.8's tier logon GPO, which keeps link order 1 on the Workstations OU: user rights don't merge across GPOs, so a STIG GPO linked above it would win and drop the denies for Tier 0, Tier 1 and SBD Audit Custodians. Every GPO this course links to the OU goes below it.
5. Create the workstation firewall GPO (SBD Workstation Firewall in this sample) on the Workstations OU: Windows Defender Firewall on for every profile with inbound traffic blocked by default, and inbound rules that allow Remote Desktop (TCP 3389) and remote management (TCP 5985–5986) only from SBD-ADMIN-PC01 at 10.0.60.30 — the ports its register row, A03, carries. No rule allows SMB or Remote Desktop between workstations: traffic inside VLAN 80 never reaches the router, so this policy, not the core router's rules, enforces the register's peer denies. Then turn off the PCs' own DNS registration in a separate GPO on the same OU (SBD Workstation DNS in this sample): Computer Configuration > Policies > Administrative Templates > Network > DNS Client > Dynamic update, Disabled. Record the reason with the GPO: SBD-DHCP01 already registers each PC's A and PTR records under svc-dhcp-

dns (course 1.7), and a client that registers its own record can take it over, so the DHCP server's account can no longer update it — one owner per record.

Check your result

```
Get-FileHash -Algorithm SHA256 C:\Staging\Windows-client-reference.vhdx
# On AdminJumpBox01 (Tier 0): the join account's delegation (svc-fleet-join in this
sample) and the OU's links
(Get-Acl 'AD:\OU=Workstations,OU=SBD,DC=sbd,DC=test').Access | Where-Object
IdentityReference -match 'svc-fleet-join|SBD Tier 2 Admins' | Select-Object
IdentityReference, ActiveDirectoryRights, ObjectType
(Get-GPInheritance -Target 'OU=Workstations,OU=SBD,DC=sbd,DC=test').GpoLinks | Select-
Object Order, DisplayName   # course 1.8's tier logon GPO stays at order 1
Get-GPOReport -Name 'SBD Workstation Firewall' -ReportType Html -Path C:\Evidence\
workstation-fleet\workstation-firewall.html
Get-GPOReport -Name 'SBD Workstation DNS' -ReportType Html -Path C:\Evidence\workstation-
fleet\workstation-dns.html
```

WHAT SUCCESS LOOKS LIKE The image is hashed and recorded, the join account holds only Create Computer objects on the Workstations OU, and the client STIG, loopback, local Administrators, firewall and DNS registration GPO links show on that OU below course 1.8's tier logon GPO, still at link order 1, before any machine exists in it.

Your record

Evidence to keep: Keep the image record with its hash, the naming and wave plan, the delegation output for the join account and SBD Tier 2 Admins, the OU's GPO links in order, and the firewall and DNS registration GPO reports with the recorded reason.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why does the join account get only create-computer rights on one OU?

REMEMBER One hashed image, one naming plan, waves instead of a big bang. The join credential can create computer objects and nothing else. The Workstations OU is armed with policy, and its managers named,

> before it holds a machine — with course 1.8's tier denies still first. Peer SMB and Remote Desktop are blocked by each PC's own firewall, set by policy before the first join.

DISA · STIG Group Policy Objects package

Microsoft · Configure Windows Firewall rules with Group Policy

Microsoft · Policy CSP – ADMX_DnsClient (Dynamic update)

Microsoft · DNS dynamic update

NIST · SP 800-53 Rev. 5 security controls

LESSON 02 / ABOUT 30 MIN

Join the pilot and inspect first boot

> **WHY THIS MATTERS** Three machines go first, and everything the path has built shows up at once: a DHCP lease through the relay, an OU landing, STIG policy, a DNS record — and the join itself appearing on the analyst's screen.

In this lesson you will

- Join a three-machine pilot with the scoped account.
- Verify lease, OU placement, policy, and DNS registration per machine.
- Confirm the joins appear in the logging pipeline.

Follow the build

1. Deploy SBD-PC01 through SBD-PC03 from the image into VLAN 80 — where the PCs are virtual machines, with the hypervisor's time synchronization turned off, as course 1.3 requires — let each take its DHCP lease, and join sbd.test with the delegated account; nothing about the join should require a privileged credential.
2. Per machine, verify the inheritance chain: the computer object sits in the Workstations OU (the course 1.5 redirect working), gpresult shows the STIG policies applied, w32tm /query /source names a domain controller, and the A and PTR records SBD-DHCP01 registered for it under svc-dhcp-dns (course 1.7) answer from both DCs — with the PC's own registration off, as lesson 1's DNS GPO set.
3. Confirm the deny side holds: a pilot machine cannot reach another pilot machine's SMB or RDP — the lesson 1 firewall policy refuses it on the destination PC, because traffic inside VLAN 80 never reaches the router — and cannot open anything toward VLAN 60, which the core router's rules deny at the boundary.
4. Find the three joins in the logging pipeline: the domain controllers' computer-account creation events (4741) should already be on the course 1.10 collector and searchable in SBD-SPLUNK01 (course 1.12) — the first machines this network has watched arrive. If the course 1.10 subscription doesn't carry 4741, add it and record the change.

Check your result

```
Get-ADComputer -SearchBase 'OU=Workstations,OU=SBD,DC=sbd,DC=test' -Filter * | Select-
Object Name, DNSHostName
gpresult /r /scope:computer
w32tm /query /source   # a domain controller, never Local CMOS Clock or the hypervisor
Resolve-DnsName SBD-PC01.sbd.test -Server SBD-DC02.sbd.test
Get-ItemProperty 'HKLM:\SOFTWARE\Policies\Microsoft\Windows NT\DNSClient' | Select-Object
RegistrationEnabled   # 0: the PC leaves registration to SBD-DHCP01
Test-NetConnection SBD-PC02.sbd.test -Port 445   # expected: TcpTestSucceeded False
```

> **WHAT SUCCESS LOOKS LIKE** All three pilots sit in the Workstations OU with STIG policy applied, time from a domain controller and DNS registered by SBD-DHCP01 on both DCs with the PC's own registration off, peer SMB/RDP fails as designed, and the join events are visible in analysis.

Your record

Evidence to keep: Keep each pilot's placement, gpresult, time source and DNS proof; the peer-deny output; and the analysis search showing the three computer-account creations.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

How does a brand-new machine end up hardened without anyone touching it?

REMEMBER Three pilots: leased, landed, hardened, registered — untouched by hand. Peer traffic fails by design; the denies are the fleet's first evidence. The pipeline watched the fleet being born.

DISA · STIG Group Policy Objects package

Microsoft · Use Windows Event Forwarding to help with intrusion detection

Microsoft · Configure Windows Firewall rules with Group Policy

LESSON 03 / ABOUT 25 MIN

Manage local administrators with Windows LAPS

> **WHY THIS MATTERS** Fifty identical machines must not share one local administrator password. Windows Local Administrator Password Solution (Windows LAPS) gives each endpoint its own rotating secret, stored in the directory, readable by the people the tier model says may have it.

In this lesson you will

- Prepare the directory schema and permissions for Windows LAPS.
- Apply the LAPS policy to the Workstations OU.
- Retrieve and rotate a managed password under the tier rules.

Follow the build

1. From AdminJumpBox01, extend the directory schema for Windows LAPS (Update-LapsADSchema, which needs Schema Admins) and grant the Workstations OU's computers the right to update their own password attributes (Set-LapsADComputerSelfPermission) — a one-time Tier 0 action, recorded like any schema change.
2. Grant read access on the managed passwords to SBD Tier 2 Admins (Set-LapsADReadPasswordPermission) — exactly the people SBD-ADMIN-PC01 exists for. Domain Admins can read them by default; no other group gets the right, and Tier 0 accounts don't sign in on workstations to use one. The tier model decides who may know an endpoint's local secret.
3. Create the LAPS GPO on the Workstations OU: back up to Active Directory, manage the local administrator account the image carries (named in the policy, because Windows LAPS manages the built-in Administrator unless told otherwise and doesn't create accounts), encrypt the password with SBD Tier 2 Admins as its authorized decryptor (otherwise only Domain Admins can decrypt it), the complexity, length and age the plan sets, and post-authentication actions that reset the password and sign the account out after a short grace period, so a used password does not live on.
4. On a pilot, confirm the policy applied, retrieve the password from SBD-ADMIN-PC01, use it once, and watch rotation after the grace period — one cycle, fully observed, is the proof the other forty-nine inherit.

Check your result

```
# On AdminJumpBox01 (Tier 0): who holds the LAPS rights on the Workstations OU
Find-LapsADExtendedRights -Identity 'OU=Workstations,OU=SBD,DC=sbd,DC=test'
# Inside SBD-ADMIN-PC01 (Tier 2)
# The LAPS cmdlets read the directory over LDAP; the AD module's web service (TCP 9389) is
open only to AdminJumpBox01
Get-LapsADPassword -Identity SBD-PC01 -AsPlainText | Select-Object ComputerName, Account,
ExpirationTimestamp
# On the pilot
gpresult /r /scope:computer
```

> **WHAT SUCCESS LOOKS LIKE** The schema holds the LAPS attributes, only SBD Tier 2 Admins (beside the default Domain Admins) can read and decrypt passwords, the policy shows on the pilots, and one retrieve-use-rotate cycle is recorded.

Your record

Evidence to keep: Keep the schema-change record, the permission delegation, the LAPS policy report, and the observed rotation cycle.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

What problem does LAPS remove from a fifty-machine fleet?

REMEMBER Every endpoint owns its own rotating local secret. Reading and decrypting rights follow the tier model, from the Tier 2 seat. One full cycle is observed and on record.

Microsoft · Windows LAPS overview

Microsoft · Get started with Windows LAPS and Windows Server Active Directory

LESSON 04 / ABOUT 25 MIN

Autoenroll the fleet's certificates

> **WHY THIS MATTERS** Course 1.6 proved autoenrollment on both domain controllers and its pilot, SBD-PKI-MGMT01; this lesson turns it loose. Widen the template permission to a fleet computer group, let the autoenrollment GPO already linked at the domain root do the enrolling, and verify a machine certificate chains and checks revocation across the boundary.

In this lesson you will

- Widen the computer template's autoenrollment to a fleet computer group.
- Confirm hands-free enrollment at Group Policy refresh.
- Verify chain and live revocation from an endpoint.

Follow the build

1. Through the course 1.6 change process (its lesson 8), grant a new computer group — SBD Fleet Computers in this sample, created from AdminJumpBox01 — Read, Enroll and Autoenroll on the SBD Computer Authentication template, from SBD-PKI-MGMT01. Template permissions name groups, never an OU; the change record names the widening and its approver.
2. Confirm with gpresult that course 1.6's SBD Certificate Autoenrollment GPO, linked at the domain root, already reaches the Workstations OU, then add the pilots to SBD Fleet Computers and restart them so the membership reaches their Kerberos tickets. Watch certificates arrive with no human in the loop: the requests reach SBD-SUBCA01 over the enrollment row course 1.6 confirmed (F23 in this sample).
3. On an enrolled pilot, export its certificate, clear the URL cache, and run the full verification: the chain must reach the approved root, and the AIA and CDP fetches must answer live from pki.sbd.test through the register's publication row, F18.
4. Record the issuing CA's view: the issued-certificate log now shows the pilots enrolling — volume the CA was designed for, beginning to arrive, and itself a record worth sampling into evidence.

Check your result

```
# On SBD-PC01, after the restart
gpupdate /force
certutil -pulse
Get-ChildItem Cert:\LocalMachine\My | Select-Object Subject, NotAfter, Thumbprint
Get-ChildItem Cert:\LocalMachine\My | Where-Object { $_.EnhancedKeyUsageList.FriendlyName
-contains 'Client Authentication' } | Select-Object -First 1 | Export-Certificate -
FilePath C:\Evidence\workstation-fleet\SBD-PC01.cer
certutil -urlcache * delete
certutil -verify -urlfetch C:\Evidence\workstation-fleet\SBD-PC01.cer   # carry the output
to SBD-ADMIN-PC01's record
```

> **WHAT SUCCESS LOOKS LIKE** Pilot endpoints enroll hands-free once they are in SBD Fleet Computers, verification passes with live publication retrieval and nothing cached, and the CA's issued log shows their SBD Computer Authentication certificates.

Your record

Evidence to keep: Keep the template change record, the SBD Fleet Computers membership, an endpoint's certificate details, the urlfetch output, and a sample of the CA's issued log.

© 2026 Secure By Design Team LLC.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

What governs widening the template from pilot to fleet?

> **REMEMBER** The widening went through the change process, not around it. Enrollment is hands-free for the fleet group and verified live across the boundary. The CA's issued log joins the evidence.

Microsoft · Configure certificate autoenrollment

NIST · SP 800-53 Rev. 5 security controls

LESSON 05 / ABOUT 30 MIN

Admit only enrolled devices with 802.1X

> **WHY THIS MATTERS** Until now, anything plugged into a VLAN 80 port got an address. With 802.1X, the switch asks each machine to prove who it is with the certificate it enrolled. This lesson turns that check on in monitor mode — every result is logged, nothing is blocked yet — because 47 PCs have no certificate until they join the domain; lesson 6 enforces it once the whole fleet has enrolled. No new server: the NPS role joins DHCP on SBD-DHCP01.

In this lesson you will

- Add the Network Policy Server (NPS) role to SBD-DHCP01 for port authentication.
- Configure Extensible Authentication Protocol–Transport Layer Security (EAP-TLS) with machine certificates on the VLAN 80 access ports, in monitor mode.
- Prove the pilots authenticate and that NPS logs every result.

Follow the build

1. Add the Network Policy Server role to SBD-DHCP01 in a Tier 1 session from SBD-ADMIN-SRV01, and register it in Active Directory from AdminJumpBox01 (a Tier 0 action: it adds the server to RAS and IAS Servers). Give it an SBD Server Authentication certificate (course 1.6) for SBD-DHCP01.sbd.test, adding SBD-DHCP01 to the SBD TLS Servers group before it requests. It handles port admission only; router logins stay named local accounts, so the server stays in the member-server tier.
2. Add the VLAN 80 access switch as a RADIUS client with a long, unique shared secret, then create the network policy: wired 802.1X, EAP-TLS only, machine certificates that chain to the approved root and carry the Client Authentication purpose, from the Domain Computers group — any domain-joined computer, servers included where one sits on an 802.1X port. Don't narrow it to SBD Fleet Computers: that group decides who enrolls the fleet's certificate, not who may connect.
3. Create quarantine VLAN 90 on the access switch with no gateway and no routes (the core gets no VLAN 90 interface) and set it as the ports' failure and guest VLAN, but enable 802.1X on the VLAN 80 access ports in monitor (audit) mode: the switch runs every authentication and reports the result, yet keeps forwarding on VLAN 80 whatever the outcome (vendors name this mode differently). The other 47 PCs have no machine certificate until they join the domain in lesson 6, so enforcing now would strand them in VLAN 90, with no route to a domain controller. Push the wired 802.1X client settings to the Workstations OU by Group Policy (Wired AutoConfig, EAP-TLS, the approved root as the trusted CA).
4. Turn on Audit Network Policy Server (success and failure) for SBD-DHCP01 in a separate GPO linked above the STIG GPO, recorded as course 1.10 records audit additions — the STIG's audit policy leaves it off. Then prove monitor mode with the pilots: each authenticates with EAP-TLS and NPS logs a grant (event 6272), while a failed attempt is logged — as event 6273 when the request reaches NPS — but still forwards on VLAN 80. Add register row F20 with its owner, as the System Hub records it, and confirm the NPS events reach the course 1.10 collector, adding 6272 and 6273 to SBD-ForwardedSecurity's query if it doesn't carry them yet.

Check your result

```
# On an enrolled pilot: the wired interface authenticated with EAP-TLS.
netsh lan show interfaces
# On SBD-DHCP01 (Tier 1): NPS auditing is on, then recent grants (6272) and denials
(6273).
```

© 2026 Secure By Design Team LLC.

```
auditpol /get /subcategory:"Network Policy Server"
Get-WinEvent -FilterHashtable @{LogName='Security'; Id=6272,6273} -MaxEvents 5 | Select-
Object TimeCreated, Id
```

WHAT SUCCESS LOOKS LIKE The network policy admits Domain Computers with EAP-TLS; NPS auditing records success and failure; every pilot authenticates with EAP-TLS and NPS logs the grant (6272); a failed authentication is logged but, in monitor mode, the port still forwards on VLAN 80; the ports name VLAN 90 as their failure VLAN; and the NPS events appear in the collector.

Your record

Evidence to keep: Keep the network policy export, the RADIUS client list (without the secret), the audit GPO report, the monitor-mode port configuration, the pilots' grant events and the failed test, and the F20 register row.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Once 802.1X is enforced, what lets a workstation onto a VLAN 80 port?

REMEMBER 802.1X runs on every VLAN 80 port in monitor mode: every result is logged, nothing is blocked yet. The pilots authenticate with machine certificates; enforcement waits until the whole fleet has enrolled. No new server: NPS runs on SBD-DHCP01, and its decisions are logged with everything else.

Microsoft · Network Policy Server overview

Microsoft · Configure RADIUS clients

Microsoft · Certificate requirements for EAP-TLS

LESSON 06 / ABOUT 30 MIN

Scale to fifty, enforce 802.1X, and prove by sample

> **WHY THIS MATTERS** Roll the remaining waves while the ports are still in monitor mode, confirm every PC enrolled its machine certificate and authenticates, then switch the ports to enforcement — and prove the fleet the only honest way at scale: a defined sample, the same checks as the pilot, and a written rule for what a sample failure means.

In this lesson you will

- Roll out the remaining endpoints in planned waves.
- Confirm fleet-wide enrollment, then enforce 802.1X and prove an unenrolled device is quarantined.
- Verify a defined sample against the pilot's full check set and enrol the fleet in event collection.

Follow the build

1. Deploy the remaining machines in the planned waves while the VLAN 80 ports are still in monitor mode, adding each wave to SBD Fleet Computers from AdminJumpBox01 and restarting it so it enrolls, and watch the DHCP scope's utilization and the join events arriving in analysis as each wave lands — the pipeline is now the rollout's progress bar.
2. Confirm every PC enrolled its machine certificate and authenticates: compare the issuing CA's issued certificates and the NPS grant events (6272) against the fifty computer objects, and fix any machine that is missing before going further. Then retire course 1.7's temporary test client, SBD-TEST80, whose Tier 2 test role the pilots now carry: remove it from the domain, delete its computer object, lease and DNS records, and record the retirement.
3. Switch the VLAN 80 access ports from monitor mode to enforcement, and prove it both ways: an enrolled PC still authenticates and gets its normal lease, and an unenrolled test laptop lands in quarantine VLAN 90 and reaches nothing. Record the switch's port status and the NPS events for both.
4. Define the sample before checking it: for example one machine per wave plus any machine that logged an error — then run the pilot's full set on each sampled host (OU, policy, DNS, LAPS, certificate, 802.1X admission, peer-deny).
5. Write the sample rule down: one failed check in the sample widens the sample; a repeated failure stops the rollout and becomes a finding. A sample without a failure rule is a formality.
6. Enrol the fleet in course 1.10's collection: from AdminJumpBox01, add SBD Fleet Computers to SBD Event Sources and link course 1.10's enrolling GPO to the Workstations OU, below course 1.8's tier logon GPO; from SBD-ADMIN-SRV01, widen the collector's WinRM 5985 scope to VLAN 80 (rule F17); restart the PCs so both apply — and confirm fleet sign-ins now appear in the analyst's searches.

Check your result

```
# On AdminJumpBox01 (Tier 0): the fleet's computer objects and its group
(Get-ADComputer -SearchBase 'OU=Workstations,OU=SBD,DC=sbd,DC=test' -Filter *).Count   # 50, once SBD-TEST80 is retired
(Get-ADGroupMember 'SBD Fleet Computers').Count   # 50
# On SBD-DHCP01: authentication results in the last hour (6272 granted, 6273 denied).
Get-WinEvent -FilterHashtable @{LogName='Security'; Id=6272,6273; StartTime=(Get-Date).AddHours(-1)} | Group-Object Id | Select-Object Name, Count
Get-DhcpServerv4ScopeStatistics -ScopeId 10.0.80.0 | Select-Object PercentageInUse, AddressesInUse
```

© 2026 Secure By Design Team LLC.

```
# On SBD-SYSLOG01: the fleet's events arriving
Get-WinEvent -LogName ForwardedEvents -MaxEvents 5 | Select-Object MachineName, Id
```

> **WHAT SUCCESS LOOKS LIKE** Fifty computer objects sit in the Workstations OU and in SBD Fleet Computers, SBD-TEST80 is retired, every PC enrolled and authenticates, the ports enforce 802.1X with the unenrolled laptop quarantined in VLAN 90, scope utilization matches the rollout, every sampled host passes the full check set, and fleet events flow through the pipeline.

Your record

Evidence to keep: Keep the wave log, the enrollment reconciliation, the SBD-TEST80 retirement record, the enforcement change with both admission results and their records, the sample definition with its failure rule, the per-sample check results, and the enrolment proof from the collector.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why prove the fleet by sample instead of checking all fifty by hand?

> **REMEMBER** Fifty machines, rolled in waves, watched as they landed. Every PC enrolled before enforcement; an unenrolled device now lands in VLAN 90. A defined sample with a failure rule carried the proof, and the fleet reports into the pipeline.

Microsoft · Configure certificate autoenrollment

Microsoft · Use Windows Event Forwarding to help with intrusion detection

NIST · SP 800-53 Rev. 5 security controls

Microsoft · Network Policy Server overview

LESSON 07 / ABOUT 30 MIN

Delta scan the fleet and hand off

> **WHY THIS MATTERS** The cadence meets its first population: the sampled endpoints get Security Content Automation Protocol (SCAP) baselines with the Windows client benchmark from SBD-ADMIN-PC01's own SCAP Compliance Checker (SCC) copy, installed in course 1.8, the infrastructure this course changed is rescanned, and the fleet inventory is handed to course 1.15.

In this lesson you will

- Baseline the sampled endpoints with the Windows client STIG benchmark from SBD-ADMIN-PC01's existing SCC copy.
- Rescan the infrastructure this course touched.
- Hand the fleet to courses 1.14 and 1.15.

Follow the build

1. Baseline the lesson 6 sample with the Windows client benchmark from SBD-ADMIN-PC01, reusing the SCC copy course 1.8 installed there and baselined the seat with — this course scans only the fleet sample. First check the installer course 1.8 kept in C:\Staging\DISA against connected-side-hashes.csv. Rule A03 carries remote management, not the file-sharing and RPC ports a remote SCC scan uses, so copy SCC to each sampled PC over PowerShell remoting, check its hash there, scan locally in a Tier 2 session, bring the results back to C:\Evidence\workstation-fleet\baseline, and remove SCC from the PC. Note how much the pre-linked policies and the OS defaults already satisfy, and classify open items the course 1.4 way.
2. Rescan what changed and attribute each delta to its lesson: the DCs (schema and LAPS attributes) and SBD-SUBCA01 (fleet enrollment volume) from AdminJumpBox01, and SBD-DHCP01 (the NPS role, its audit GPO and a scope in daily use) locally in a Tier 1 session from SBD-ADMIN-SRV01. Send any new deviation to the exception record's owner on AdminJumpBox01.
3. Assemble the fleet inventory — names, image ancestry, certificate thumbprints, sample status — as the course's closing artifact; course 1.15 makes it a source of SBD-MGMT01's living inventory.
4. Write the handoff: the fleet exists, watched and hardened, but takes no updates yet — course 1.14 builds SBD-WSUS01, with SBD-PC01–SBD-PC03 as its pilot ring and the other 47 PCs as Ring 2, and course 1.15 keeps the inventory current.

Check your result

```
# Inside SBD-ADMIN-PC01 (Tier 2): the installer course 1.8 kept still matches the record
(expected: True)
$scc = Get-Item 'C:\Staging\DISA\<SCC installer>'
(Get-FileHash $scc.FullName -Algorithm SHA256).Hash -in (Import-Csv C:\Staging\DISA\
connected-side-hashes.csv).Hash
# Per sampled PC: carry the installer over remote management (A03), install and scan
there, bring the results back
$s = New-PSSession SBD-PC07.sbd.test
Copy-Item $scc.FullName -ToSession $s -Destination C:\Windows\Temp\
Copy-Item '<SCC results folder on the PC>' -FromSession $s -Destination C:\Evidence\
workstation-fleet\baseline\SBD-PC07 -Recurse
# After the scans: this seat's record, hashed
Get-ChildItem C:\Evidence\workstation-fleet -Recurse -File | Get-FileHash -Algorithm
SHA256 | Export-Csv C:\Evidence\workstation-fleet-manifest.csv -NoTypeInformation
```

WHAT SUCCESS LOOKS LIKE The installer course 1.8 kept on SBD-ADMIN-PC01 still matches its recorded hash, the sampled endpoints hold dated Windows client baselines with SCC removed afterwards, the infrastructure rescans carry attributed deltas, and the fleet inventory is complete and filed.

Your record

Evidence to keep: Finish the checklist: the installer's hash check, the endpoint baselines, infrastructure rescans, the fleet inventory, the hashed manifest, and the handoff note to courses 1.14 and 1.15.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Which benchmark do the endpoints get?

REMEMBER The endpoints are baselined by sample from SBD-ADMIN-PC01's existing SCC copy. Infrastructure deltas are attributed, and the fleet inventory is the closing artifact. The gap — updates and a living inventory — is named for courses 1.14 and 1.15.

DISA · STIG Group Policy Objects package

NIST · SP 800-53 Rev. 5 security controls

DISA · Security Content Automation Protocol (SCC and SCAP benchmarks)

Course review and sign-off

Before moving on, confirm each lesson left evidence behind — and that what remains open is written down, not remembered.

Lesson completion

LESSON	EVIDENCE FILED	DATE
01 Prepare the fleet rollout	☐ yes	
02 Join the pilot and inspect first boot	☐ yes	
03 Manage local administrators with Windows LAPS	☐ yes	
04 Autoenroll the fleet's certificates	☐ yes	
05 Admit only enrolled devices with 802.1X	☐ yes	
06 Scale to fifty, enforce 802.1X, and prove by sample	☐ yes	
07 Delta scan the fleet and hand off	☐ yes	

Open items carried forward

Next in the learning path

That completes course 1.13. Course 1.14 builds SBD-WSUS01 and delivers the fleet's first Windows updates, ring by ring, starting with SBD-PC01–SBD-PC03.

> **KEEP IT HONEST** Lesson completion records learning activity; it is not a system authorization decision. Your observations, not the sample values, establish what happened in your environment.

© 2026 Secure By Design Team LLC.